به نام خدا

تمرین اول درس تشخیص نفوذ

دانشگاه صنعتی امیرکبیر - دانشکده مهندسی کامپیوتر
نام درس: تشخیص نفوذ
طراح : سروش بابایی

قوانین کلی انجام تمرین‌ها

تمامی بخش‌های این تمرین صرفاً در محیط‌های آزمایشگاهی ایزوله (Host-only یا Internal Network، بدون اتصال به شبکه واقعی یا اینترنت عمومی) انجام می‌شوند. هدف از این تمرین، آشنایی با روش تحلیل تهدید، اعتبارسنجی آسیب‌پذیری و طراحی سازوکارهای شناسایی و دفاع است، نه توسعه یا استفاده از ابزار علیه سامانه‌های واقعی. در بخش‌هایی که از منابع آزاد اینترنتی (مانند Shodan) استفاده می‌شود، تعامل صرفاً محدود به مشاهده و تحلیل آماری نتایج است و هرگونه اسکن یا اتصال فعال به سامانه‌های واقعی در معرض اینترنت مجاز نیست.

۱ تمرین اول: تحلیل یک کمپین سایبری واقعی با MITRE ATT&CK و طراحی راهکارهای دفاعی با MITRE D3FEND

منبع

فایل گزارش مربوط به کمپین TangerineTurkey و باتنت مورد استفاده، که توسط تیم CTI شرکت گراف منتشر شده است، در اختیار شما قرار می‌گیرد. تمام مراحل این تمرین را بر اساس اطلاعات و شواهد موجود در این گزارش انجام دهید.

شرح تمرین

بخش اول: نگاشت رفتارهای مهاجم به ATT&CK

رفتارهای مهاجم را که در گزارش مستند شده‌اند، به تاکتیک‌ها (Tactics) و تکنیک‌ها یا زیرتکنیک‌های (Techniques/Sub-techniques) متناظر در چارچوب MITRE ATT&CK نگاشت کنید و جدول زیر را تکمیل کنید.

تاکتیک	تکنیک (ID)	شاهد از گزارش	سطح اطمینان

الزامات این بخش:

- فقط رفتارهایی را نگاشت کنید که در گزارش مستند شده‌اند. اگر شواهد کافی برای نگاشت یک مرحله یا تکنیک مشخص، مانند Initial Access، وجود ندارد، عبارت «شواهد ناکافی» را درج کنید و دلیل خود را توضیح دهید.
- نسخه چارچوب ATT&CK مورد استفاده را مشخص کنید.
- حداقل هشت رفتار یا تکنیک را نگاشت کنید.

بخش دوم: طراحی راهکارهای دفاعی با D3FEND

برای حداقل پنج مورد از تکنیک‌های شناسایی‌شده در بخش اول، با مراجعه به چارچوب MITRE D3FEND به نشانی d3fend.mitre.org، راهکارهای دفاعی مرتبط را شناسایی و بررسی کنید. برای هر مورد، موارد زیر را ارائه دهید:

- تکنیک دفاعی متناظر در D3FEND و دسته دفاعی مرتبط با آن.
- نحوه پیاده‌سازی عملی راهکار دفاعی در محیط یک سازمان دارای زیرساخت‌های حیاتی و حساس.
- مشخص کنید که راهکار انتخاب‌شده چگونه به پیشگیری از حمله، شناسایی آن یا کاهش اثرات آن کمک می‌کند.

۲ تمرین دوم: اعتبارسنجی یک آسیب‌پذیری بحرانی و طراحی سازوکار شناسایی آن

محیط آزمایش

دو ماشین مجازی (VM) را در یک شبکه داخلی ایزوله از نوع Host-only یا Internal Network راه‌اندازی کنید:

- **ماشین آزمایش:** مجهز به Docker و Docker Compose و میزبان سرویس آسیب‌پذیر.
- **ماشین تحلیل:** ترجیحاً مجهز به Kali Linux.

ریپازیتوری Vulhub را روی ماشین آزمایش دریافت کنید:

```
git clone https://github.com/vulhub/vulhub
```

مراحل انجام تمرین

۱. از میان سناریوهای موجود در Vulhub، یک آسیب‌پذیری بحرانی (Critical) با امتیاز CVSS برابر با ۰.۹ یا بالاتر انتخاب کنید که امکان اجرای کد از راه دور (RCE) یا ایجاد شل را فراهم کند. اطلاعات سناریو را بررسی و امتیاز آسیب‌پذیری را از پایگاه NVD به نشانی nvd.nist.gov اعتبارسنجی کنید.

۲. محیط آزمایش مربوط به CVE انتخاب‌شده را راه‌اندازی کنید. برای مثال، در پوشه سناریوی مربوطه دستور زیر را اجرا کنید:

```
docker compose up -d
```

۳. از ماشین تحلیل، سرویس را بررسی کنید. نسخه نرم‌افزار، اطلاعات Banner و اثرانگشت سرویس (Fingerprint) را استخراج کرده و شواهد مربوط به تطبیق سرویس با آسیب‌پذیری انتخاب‌شده را ثبت کنید.

۴. یک کد اثبات مفهوم (PoC) عمومی از منبعی معتبر، مانند Exploit-DB، GitHub Advisory یا منابع ارجاع‌شده در NVD، پیدا کنید. منطق عملکرد، پیش‌نیازها و اثرات احتمالی اجرای آن را بررسی و مستند کنید.

۵. در محیط آزمایش ایزوله، PoC را اجرا کنید و امکان بهره‌برداری از آسیب‌پذیری را بررسی کنید. در صورت موفقیت، ایجاد شل از نوع Reverse Shell یا Bind Shell را در همان محیط اعتبارسنجی کنید. هدف از این مرحله صرفاً تأیید عملی وجود آسیب‌پذیری برای تکمیل مراحل بعدی تمرین است.

۶. نتیجه را با شواهدی مانند خروجی دستورات `id`، `whoami` یا `hostname` مستند کنید و سطح دسترسی حاصل‌شده را توضیح دهید.

بخش تحلیل مواجهه با تهدید با Shodan

با استفاده از Shodan به نشانی shodan.io، درباره CVE انتخاب‌شده جست‌وجو کنید و تعداد نتایج مرتبط با سرویس‌های در معرض اینترنت را گزارش دهید. از نتایج اسکرین‌شات تهیه کنید و توضیح دهید که این داده‌ها چه شواهدی درباره میزان مواجهه با آسیب‌پذیری فراهم می‌کنند و چه محدودیت‌هایی در تشخیص

قطعی سامانه‌های آسیب‌پذیر دارند. در این بخش صرفاً مجاز به مشاهده و تحلیل آماری نتایج Shodan هستید؛ هرگونه اتصال، اسکن یا تعامل فعال با سامانه‌های واقعی یافت‌شده در نتایج ممنوع است.

۳ تمرین سوم: بررسی ساختارهای پردازش و ترد در ویندوز با WinDbg

محیط آزمایش

یک ماشین مجازی ویندوزی با قابلیت Kernel Debugging راه‌اندازی کنید. برای بررسی ساختارهای داخلی کرنل، از WinDbg و نمادهای متناسب با نسخه ویندوز استفاده کنید.

برنامه ارائه‌شده را کامپایل و اجرا کنید. این برنامه شناسه پردازش (PID) و شناسه ترد (TID) جاری را دریافت کرده و در فایل زیر ذخیره می‌کند:

```
C:\Users\Public\process_info.txt
```

مراحل انجام تمرین

نکته: فایل `rev.c` برای انجام این تمرین در اختیار شما قرار گرفته است.

۱. **بررسی فهرست پردازش‌ها**

با استفاده از WinDbg، فهرست پردازش‌های در حال اجرای سیستم را استخراج کنید. حداقل اطلاعات لازم برای شناسایی هر پردازش، از جمله PID و نام آن، را نمایش دهید و روش مورد استفاده برای استخراج این اطلاعات را توضیح دهید.

۲. **بررسی ساختار EPROCESS**

پردازش مربوط به برنامه ارائه‌شده را پیدا کنید و ساختار داخلی EPROCESS_ آن را با استفاده از WinDbg بررسی کنید. آدرس ساختار در حافظه و فیلدهای مرتبط با شناسه پردازش را استخراج کنید.

مقدار فیلد UniqueProcessId را با PID ثبت‌شده در فایل متنی مقایسه کنید و نتیجه را به همراه شواهد لازم گزارش دهید.

۳. **بررسی فضای آدرس پردازش**

فضای آدرس مجازی پردازش جاری را با استفاده از WinDbg بررسی کنید. آدرس پایه و محدوده بخش‌های قابل مشاهده در فضای آدرس پردازش را استخراج کنید و تفاوت میان فضای آدرس مجازی، حافظه فیزیکی و آدرس ساختار EPROCESS_ را توضیح دهید.

مشخص کنید کدام بخش از اطلاعات مشاهده‌شده به فضای آدرس پردازش کاربر و کدام بخش به حافظه کرنل مربوط است.

۴. **بررسی فیلد Protection**

فیلد Protection در ساختار EPROCESS_ را در صورت وجود در نسخه ویندوز مورد استفاده بررسی کنید. مفهوم محافظت از پردازش و ارتباط آن با سازوکارهای Protected Process و Protected Process Light (PPL) را توضیح دهید.

مقدار مشاهده‌شده را مستند کنید و اجزای آن را بر اساس مستندات یا تحلیل فنی معتبر تفسیر کنید.

۵. **بررسی اولویت ترد**

مفهوم Thread Priority را توضیح دهید و تفاوت اولویت ترد با اولویت پایه پردازش را مشخص کنید. محدوده سطوح اولویت زمان‌بند ویندوز را بیان کنید و توضیح دهید که مقادیر نسبی تعیین‌شده از طریق WinAPI چگونه در تعیین اولویت نهایی ترد مؤثر هستند.

بررسی کنید افزایش اولویت یک ترد چه تأثیری می‌تواند بر زمان‌بندی، سهم دریافت CPU و اجرای تردهای دیگر داشته باشد.

۶. **ردیابی مسیر WriteFile**

اجرای تابع WriteFile در برنامه ارائه‌شده را با استفاده از WinDbg و بررسی کد اسمبلی دنبال کنید. مسیر اجرای تابع را از لایه WinAPI تا لایه‌های پایین‌تر سیستم بررسی کنید و مشخص کنید عملیات نوشتن فایل چگونه به سرویس‌های سیستم‌عامل می‌رسد.

توضیح دهید که آیا WriteFile مستقیماً یک دستور سیستمی (System Call) است یا از لایه‌های واسط استفاده می‌کند. مسیر مشاهده‌شده، توابع میانی و در صورت امکان نقطه ورود به کرنل را مستند کنید.

۷. **مستندسازی نتایج**

برای هر بخش، دستورات استفاده‌شده در WinDbg، خروجی‌های مرتبط و اسکرین‌شات‌های لازم را ارائه دهید. در تحلیل خود، تفاوت میان آنچه مستقیماً مشاهده کرده‌اید و آنچه از روی ساختارها یا مستندات نتیجه گرفته‌اید، مشخص کنید.

۳-۱ تمرین امتیازی / چالشی: فارنزیک حافظه یک سامانه آلوده به Stuxnet با Volatility

یک فایل دامپ حافظه (vmem.) مربوط به سامانه‌ای آلوده به بدافزار تاریخی Stuxnet (W32.Stuxnet، سال ۲۰۱۰) در اختیار شما قرار می‌گیرد. این بدافزار یکی از مستندترین نمونه‌های بدافزاری در ادبیات امنیت است و زیرساخت فرماندهی و کنترل (C2) آن سال‌هاست غیرفعال شده است؛ هدف این تمرین صرفاً آشنایی با روش فارنزیک حافظه (Memory Forensics) و استخراج شاخص‌های نفوذ (IOC) از یک دامپ حافظه است، نه اجرا یا بازتولید بدافزار. تحت هیچ شرایطی نباید فایل اجرایی استخراج‌شده از این دامپ را اجرا کنید؛ تمام تحلیل‌ها باید به‌صورت استاتیک و در محیط ایزوله (بدون اتصال به اینترنت) انجام شوند.

مراحل انجام تمرین

۱. **شناسایی پروفایل سیستم‌عامل:** با استفاده از Volatility (نسخه ۲ یا ۳)، پروفایل سیستم‌عامل مربوط به دامپ حافظه را شناسایی کنید (در صورت استفاده از Volatility 2، از پلاگین imageinfo کمک بگیرید).

۲. **استخراج فهرست پردازش‌ها:** با استفاده از پلاگین‌های pslist، pstree و psscan، فهرست پردازش‌های در حال اجرا را استخراج کنید. پردازش‌هایی که فاقد والد قابل‌توجیه هستند، از مسیرهای غیرمعمول اجرا شده‌اند یا نام فایل‌شان با الگوهای شناخته‌شده Stuxnet مطابقت دارد را مشخص کنید.

۳. **شناسایی اتصالات شبکه و زیرساخت C2:** با استفاده از پلاگین netscan (یا connscan در صورت عدم پشتیبانی پروفایل از netscan)، اتصالات شبکه فعال و بسته را استخراج کنید. آدرس IP و دامنه

مرتبط با C2 را شناسایی کنید.

۴. **اعتبارسنجی با منابع عمومی:** شاخص‌های استخراج‌شده (دامنه، IP، نام پردازش) را با گزارش‌های عمومی منتشرشده درباره Stuxnet (مانند گزارش W32.Stuxnet Dossier شرکت Symantec یا تحلیل Kaspersky) مقایسه و مستند کنید که آیا با شواهد منتشرشده مطابقت دارند یا خیر.

۵. **استخراج پردازش مشکوک و بررسی ساختار PE:** با استفاده از پلاگین procdump، پردازش شناسایی‌شده مرتبط با Stuxnet را از حافظه استخراج کنید. ساختار PE فایل استخراج‌شده (Headers، Sections، جدول Imports) را با ابزاری مانند pefile در پایتون یا CFF Explorer بررسی و مستند کنید.

۶. **مقایسه و نتیجه‌گیری:** ویژگی‌های ساختاری استخراج‌شده (مانند بخش‌های غیرمعمول، Entropy بالا نشان‌دهنده Packing، یا توابع Import مشکوک) را با تحلیل‌های عمومی منتشرشده از نمونه‌های Stuxnet مقایسه کنید و نتیجه بگیرید که آیا شواهد به‌دست‌آمده با رفتار شناخته‌شده این بدافزار همخوانی دارد.

بخش تکمیلی (اختیاری): شناسایی اجزای Rootkit

- با استفاده از پلاگین‌های modscan و driverscan، فهرست درایورهای بارگذاری‌شده در هسته سیستم را استخراج کنید و درایورهای مرتبط با Stuxnet (که به‌صورت Rootkit برای پنهان‌سازی فایل‌ها عمل می‌کردند) را شناسایی کنید. آدرس پایه، مسیر فایل و وضعیت امضای دیجیتال هر درایور را گزارش دهید.
- با استفاده از پلاگین malfind، نواحی حافظه با نشانه‌های احتمالی تزریق کد (Code Injection) را در پردازش‌های سالم سیستم بررسی کنید.
- با استفاده از پلاگین handles، Mutexهای ایجادشده توسط پردازش مشکوک را استخراج کنید و بررسی کنید که آیا با Mutexهای شناخته‌شده Stuxnet در گزارش‌های عمومی مطابقت دارند.

راهنمایی و پشتیبانی: در صورت نیاز به راهنمایی یا هرگونه سؤال در خصوص انجام تمرین‌ها، می‌توانید از طریق گروه بله یا تلگرام با آیدی @typedef_sia ارتباط بگیرید.